



Proof of Concept



Índice

1. Introducción	2
2. Objetivo	2
3. Alcance de la evaluación	3
3.1. Activos Incluidos en Alcance	3
3.2. Tipos de Evaluación Incluidos	3
4. Escenarios de validación sugeridos	4
4.1. Escaneo de Red No Autenticado	4
4.2. Escaneo de Vulnerabilidades Autenticado	4
4.3. Evaluación de Configuración de Seguridad	4
4.4. Evaluación de Cumplimiento (Compliance Assessment)	5
5. Prerrequisitos del Proof of Concept (PoC)	5
5.1. Prerrequisitos Técnicos	5
5.2. Credenciales y Accesos	5
5.3. Requerimientos del Scanner	6
5.4. Exclusiones y Permisos de Seguridad	6
5.5. Inventario de Activos	6
5.6. Requerimientos Operativos	6
5.7. Consideraciones Importantes	6
6. Criterios de aceptación	7
6.1. Criterios Técnicos	7
6.2. Criterios Operativos	7
6.3. Validación de Resultados	7
6.4. Entregables esperados	8
7. Cronograma de actividades.	8
7.1. Planificación General	8
7.2. Detalle de actividades	8
7.3. Consideraciones del cronograma	9
8. Criterio de éxito global	9
8.1. Criterios de éxito técnico	9
8.2. Criterios de éxito operativo	10
8.3. Validación del valor de la solución	10
8.4. Validación final del cliente	10
9. Cierre	10
9.1. Actividades de cierre	10
9.2. Entregables finales	11
10. Roles y responsabilidades	11
10.1. Responsabilidades del cliente	11
10.2. Responsabilidades del equipo técnico	11
10.3. Consideraciones generales	11

1. Introducción

El presente documento describe el desarrollo del Proof of Concept (PoC) de la plataforma SAINT Security Suite, desarrollada por SAINT Corporation, el cual será ejecutado con el propósito de validar las capacidades de la solución en la identificación de vulnerabilidades, evaluación de configuraciones de seguridad y análisis de la postura de ciberseguridad dentro del entorno tecnológico del cliente.

Este PoC tiene como finalidad proporcionar una validación técnica controlada que permita demostrar el valor operativo y estratégico de la solución, mediante la ejecución de evaluaciones de seguridad autorizadas sobre activos representativos previamente definidos en conjunto con el cliente. Las actividades serán realizadas de manera planificada y coordinada, asegurando que las pruebas se ejecuten sin generar impactos negativos en la operación productiva del entorno evaluado.

A través de este ejercicio, se busca obtener visibilidad sobre la exposición a riesgos de seguridad existentes, validar la efectividad de los mecanismos actuales de protección, y proporcionar información técnica accionable que permita apoyar la toma de decisiones relacionadas con la gestión de vulnerabilidades y mejora continua de la postura de seguridad.

El documento establece de manera estructurada los objetivos del PoC, el alcance técnico de la evaluación, los escenarios de validación, los criterios de éxito, el cronograma estimado de ejecución, así como los roles y responsabilidades de las partes involucradas durante el desarrollo de la prueba.

Este PoC servirá como base técnica para determinar la viabilidad de adopción de la solución, proporcionando evidencia objetiva sobre su capacidad para apoyar los procesos de identificación, priorización y gestión de riesgos de ciberseguridad dentro del entorno del cliente.

2. Objetivo

El objetivo del presente Proof of Concept (PoC) es validar de manera práctica y controlada las capacidades de la plataforma SAINT Security Suite, desarrollada por SAINT Corporation, para identificar vulnerabilidades, configuraciones inseguras y riesgos de seguridad dentro del entorno tecnológico del cliente.

Este ejercicio busca demostrar la efectividad de la solución en la ejecución de evaluaciones de seguridad mediante escaneos autenticados y no autenticados, permitiendo obtener visibilidad sobre la exposición real a amenazas, así como sobre el estado actual de cumplimiento de buenas prácticas de seguridad.

De manera específica, el PoC tiene como objetivos:

- Validar la capacidad de la solución para identificar vulnerabilidades críticas, altas y medias dentro de los activos incluidos en el alcance definido.
- Confirmar la efectividad de los escaneos autenticados para obtener visibilidad profunda del estado de seguridad de los sistemas operativos, aplicaciones y configuraciones.
- Evaluar la capacidad de la plataforma para identificar software vulnerable, parches faltantes y desviaciones de configuración segura.
- Validar la generación de reportes técnicos y ejecutivos que permitan priorizar riesgos y facilitar la toma de decisiones.
- Demostrar la facilidad de operación, estabilidad del proceso de escaneo y calidad de la información generada durante la evaluación.

A través de este PoC, se busca proporcionar al cliente evidencia técnica objetiva que permita evaluar el valor de la solución en el fortalecimiento de sus procesos de gestión de vulnerabilidades, mejora continua de la postura de ciberseguridad y soporte a estrategias de reducción de riesgo tecnológico.

3. Alcance de la evaluación

El presente Proof of Concept (PoC) contempla la evaluación de las capacidades de la plataforma SAINT Security Suite, desarrollada por SAINT Corporation, mediante la ejecución de actividades controladas de análisis de vulnerabilidades y evaluación de configuración de seguridad sobre activos representativos del entorno del cliente.

El alcance de la evaluación será definido en conjunto con el cliente antes del inicio de las actividades técnicas, considerando la criticidad de los sistemas, disponibilidad operativa y viabilidad técnica de los procesos de escaneo.

La evaluación se enfocará en validar la visibilidad de la postura de seguridad del entorno mediante la identificación de vulnerabilidades conocidas, configuraciones inseguras, software vulnerable y desviaciones de cumplimiento respecto a buenas prácticas de seguridad.

3.1. Activos Incluidos en Alcance

El PoC podrá incluir, dependiendo de la definición acordada con el cliente, los siguientes tipos de activos:

- Servidores Windows
- Servidores Linux
- Equipos de red (routers, switches, firewalls, si aplica)
- Infraestructura virtual (hipervisores y máquinas virtuales)
- Equipos de usuario final
- Servicios expuestos en red interna o externa

La cantidad exacta de activos será definida durante la fase inicial del PoC.

3.2. Tipos de Evaluación Incluidos

Durante el PoC se podrán ejecutar los siguientes tipos de evaluación:

Escaneo de Vulnerabilidades de Red (No Autenticado)

Evaluación de superficie de ataque visible desde red, identificando servicios expuestos y vulnerabilidades detectables sin credenciales.

Escaneo de Vulnerabilidades Autenticado

Evaluación profunda mediante credenciales autorizadas para identificar vulnerabilidades internas, configuraciones inseguras, parches faltantes y software vulnerable.

Evaluación de Configuración de Seguridad

Validación de configuraciones del sistema operativo y aplicaciones contra buenas prácticas de seguridad.

Evaluación de Cumplimiento (Compliance Assessment)

Comparación del estado de configuración contra estándares de seguridad y marcos de referencia aplicables.

4. Escenarios de validación sugeridos

Durante el desarrollo del Proof of Concept (PoC), se ejecutarán distintos escenarios de validación utilizando la plataforma SAINT Security Suite, con el fin de demostrar sus capacidades técnicas en la identificación de vulnerabilidades, análisis de configuraciones de seguridad y visibilidad de la postura de ciberseguridad del entorno evaluado.

Los escenarios definidos permitirán validar la operación de la solución en condiciones controladas y representativas del entorno real del cliente, asegurando la obtención de resultados medibles y técnicamente verificables.

4.1. Escaneo de Red No Autenticado

Descripción:

Se ejecutará un escaneo de vulnerabilidades sin uso de credenciales, con el objetivo de identificar la superficie de ataque visible desde la red, incluyendo servicios expuestos, versiones detectables y vulnerabilidades conocidas.

Objetivo:

Validar la capacidad de la solución para detectar exposición externa y vulnerabilidades accesibles sin autenticación.

Métricas de Validación:

- Identificación de servicios activos
- Detección de vulnerabilidades externas
- Precisión en identificación de sistemas operativos y servicios

4.2. Escaneo de Vulnerabilidades Autenticado

Descripción:

Se ejecutará un escaneo utilizando credenciales autorizadas para obtener visibilidad profunda del estado de seguridad de los sistemas incluidos en el alcance.

Objetivo:

Validar la capacidad de la solución para identificar vulnerabilidades internas, configuraciones inseguras, software vulnerable y parches faltantes.

Métricas de Validación:

- Estado de autenticación (fail/success)
- Vulnerabilidades internas detectadas
- Inventario de software identificado
- Identificación de parches faltantes

4.3. Evaluación de Configuración de Seguridad

Descripción:

Se evaluarán configuraciones del sistema operativo y servicios críticos contra buenas prácticas de seguridad.

Objetivo:

Identificar desviaciones de configuraciones seguras que puedan representar riesgos de seguridad.

Métricas de Validación:

- Cantidad de controles evaluados
- Cantidad de desviaciones detectadas
- Recomendaciones de remediación generadas

4.4. Evaluación de Cumplimiento (Compliance Assessment)

Descripción:

Se comparará el estado actual de configuración contra estándares de seguridad aplicables definidos previamente con el cliente.

Objetivo:

Validar la capacidad de la solución para medir postura de cumplimiento y generar recomendaciones de mejora.

Métricas de Validación:

- Score de cumplimiento obtenido
- Controles cumplidos o no cumplidos
- Recomendaciones técnicas generadas

5. Prerrequisitos del Proof of Concept (PoC)

Para garantizar una correcta ejecución del Proof of Concept (PoC) de la solución SAINT Corporation SAINT Security Suite, es necesario que el cliente cumpla previamente con una serie de prerrequisitos técnicos, operativos y administrativos.

Estos prerrequisitos permitirán asegurar la estabilidad de las evaluaciones, la correcta autenticación de los escaneos y la obtención de resultados confiables durante el periodo de validación.

5.1. Prerrequisitos Técnicos

El cliente deberá proporcionar:

- Conectividad de red entre el servidor de escaneo y los activos objetivo.
- Resolución DNS funcional dentro del entorno evaluado.
- Acceso a los segmentos de red incluidos en el alcance del PoC.
- Autorización previa de puertos requeridos para escaneo y autenticación.
- Sin restricciones de firewall que impidan comunicación entre el scanner y los objetivos.

5.2. Credenciales y Accesos

Para evaluaciones autenticadas, el cliente deberá proporcionar credenciales con permisos adecuados según el tipo de activo: **Sistemas Windows**

- Cuenta con privilegios administrativos locales o equivalentes.
- Acceso WMI habilitado.
- SMB accesible.
- Remote Registry habilitado (si aplica).

Sistemas Linux / Unix

- Credenciales SSH válidas.
- Permisos suficientes para auditoría de configuración y paquetes instalados.
- Servicio SSH habilitado y accesible.

Infraestructura Virtual

- Credenciales de acceso a VMware ESXi, vCenter o hipervisor correspondiente.
- Permisos de lectura necesarios para recopilación de información.

Equipos de Red

- Acceso SNMP o SSH/Telnet según capacidades del dispositivo.

- Credenciales válidas.

5.3. Requerimientos del Scanner

El entorno destinado al servidor o appliance de escaneo deberá cumplir con:

- Recursos de CPU, memoria y almacenamiento adecuados al tamaño del alcance.
- Acceso estable a red interna.
- Dirección IP fija.
- Sin políticas que limiten el tráfico de escaneo interno.

5.4. Exclusiones y Permisos de Seguridad

El cliente deberá considerar:

- Exclusiones temporales en EDR/Antivirus si interfieren con el proceso de escaneo.
- Permitir tráfico generado por la plataforma durante el PoC.
- Validar que herramientas IPS/IDS no bloqueen el scanner automáticamente.

5.5. Inventario de Activos

El cliente deberá proporcionar:

- Listado de direcciones IP o rangos a evaluar.
- Identificación de activos críticos o sensibles.
- Clasificación básica de los sistemas incluidos:
 - Servidores Windows
 - Servidores Linux
 - Equipos de red
 - Infraestructura virtual
 - Endpoints
- Identificación de activos fuera de alcance.

5.6. Requerimientos Operativos

- Designación de un responsable técnico del cliente.
- Definición clara del alcance de activos.
- Ventanas autorizadas para ejecución de escaneos.
- Disponibilidad del equipo técnico durante validaciones y revisiones.

5.7. Consideraciones Importantes

- Las evaluaciones serán ejecutadas únicamente sobre activos autorizados por el cliente.
- Cualquier cambio en el alcance deberá ser validado previamente.
- El rendimiento del escaneo puede variar dependiendo de restricciones de red, autenticación o capacidad de los activos evaluados.

6. Criterios de aceptación

Los criterios de validación establecen las condiciones mínimas necesarias para determinar que el Proof of Concept (PoC) ha sido ejecutado de manera satisfactoria, permitiendo evaluar objetivamente las capacidades de la plataforma SAINT Security Suite, desarrollada por SAINT Corporation, dentro del entorno tecnológico del cliente.

Estos criterios permiten asegurar que los resultados obtenidos sean medibles, verificables y alineados con los objetivos definidos para la evaluación.

6.1. Criterios Técnicos

El PoC será considerado técnicamente satisfactorio si se cumplen las siguientes condiciones:

- Los escaneos de vulnerabilidades son ejecutados correctamente dentro del alcance definido.
- Se logra la ejecución exitosa de escaneos autenticados sobre los activos objetivo.
- Se identifican vulnerabilidades reales y verificables en los sistemas evaluados.
- Se detectan configuraciones inseguras o desviaciones de buenas prácticas de seguridad.
- Se obtiene visibilidad del inventario de software y estado de parches de los activos evaluados.
- Se generan reportes técnicos completos con información detallada de hallazgos y recomendaciones de remediación.

6.2. Criterios Operativos

Desde el punto de vista operativo, el PoC será considerado satisfactorio si:

- Las actividades son ejecutadas dentro de las ventanas de tiempo acordadas con el cliente.
- No se generan impactos críticos en la operación productiva del entorno evaluado.
- El cliente participa en las sesiones de revisión técnica de resultados.

6.3. Validación de Resultados

La validación final de los resultados considerará:

- Confirmación por parte del cliente de la visibilidad obtenida sobre su postura de seguridad.
- Validación de la utilidad de los reportes generados para procesos de gestión de vulnerabilidades.
- Confirmación de que la información generada permite priorizar riesgos de forma efectiva.

6.4. Entregables esperados

Al finalizar el PoC se deberán entregar:

- Reporte técnico detallado de vulnerabilidades detectadas.
- Resumen ejecutivo con hallazgos relevantes y recomendaciones
- Evidencia técnica de ejecución de escaneos (según aplique).

7. Cronograma de actividades.

El siguiente cronograma presenta la planificación estimada para la ejecución del Proof of Concept (PoC) utilizando la plataforma SAINT Security Suite.

Las actividades serán coordinadas entre el equipo técnico responsable de la ejecución del PoC y el cliente, siguiendo una secuencia lógica que permita asegurar la correcta preparación del entorno, ejecución de evaluaciones y presentación de resultados.

El cronograma podrá ajustarse de acuerdo con la disponibilidad del cliente, complejidad técnica del entorno y tiempos requeridos para la correcta configuración de accesos y credenciales.

7.1. Planificación General

Detalles de tiempos propuesto para desarrollo de PoC

Fase	Actividad	Duración Estimada	Responsable
Fase 1	Reunión de inicio (Kickoff)	1 hora	Cliente / Equipo Técnico
Fase 2	Configuración inicial de escaneo	1 – 2 horas	Equipo Técnico
Fase 3	Ejecución de escaneos	1 – 3 días (según alcance)	Equipo Técnico
Fase 4	Análisis de resultados	4 – 8 horas	Equipo Técnico
Fase 5	Presentación de resultados	1 – 2 horas	Cliente / Equipo Técnico

Cuadro 1: Plan de fases del proyecto

7.2. Detalle de actividades

Kickoff y Definición de Alcance

Durante esta fase se realizará la reunión inicial para:

- Confirmar alcance técnico
- Definir activos a evaluar
- Validar ventanas de ejecución
- Confirmar responsables técnicos
- Revisar requerimientos técnicos

Configuración Inicial

- Configuración de targets de escaneo
- Configuración de credenciales (si aplica)
- Validación de conectividad
- Pruebas iniciales de escaneo

Ejecución de Evaluaciones

Durante esta fase se ejecutarán:

- Escaneos de red no autenticados
- Escaneos autenticados
- Evaluaciones de configuración
- Evaluaciones de cumplimiento (si aplica)

Análisis técnico

- Revisión de hallazgos
- Validación de resultados
- Priorización de riesgos
- Preparación de reportes

Presentación y cierre

- Presentación de resultados técnicos
- Presentación de resumen ejecutivo
- Recomendaciones de remediación
- Sesión de preguntas técnicas

7.3. Consideraciones del cronograma

- Las fechas específicas serán definidas en conjunto con el cliente.
- La duración puede variar dependiendo del número de activos incluidos en el PoC.
- Se recomienda ejecutar las fases de forma continua para mantener consistencia técnica.

8. Criterio de éxito global

Los criterios de éxito global permiten determinar si el Proof of Concept (PoC) ha cumplido con los objetivos técnicos y operativos establecidos para la evaluación de la plataforma SAINT Security Suite.

El éxito del PoC será evaluado considerando los resultados obtenidos durante la ejecución técnica, el cumplimiento del cronograma definido y la validación del valor operativo de la solución por parte del cliente.

8.1. Criterios de éxito técnico

El PoC será considerado técnicamente exitoso si se cumplen las siguientes condiciones:

- Se logra escanear exitosamente la mayoría de los activos definidos dentro del alcance acordado.
- Se obtiene un porcentaje alto de autenticación exitosa en los sistemas donde se configuraron credenciales.
- Se identifican vulnerabilidades reales dentro del entorno evaluado.
- Se detectan desviaciones de configuración de seguridad o incumplimientos de buenas prácticas.
- Se genera información suficiente para permitir análisis y priorización de riesgos.

8.2. Criterios de éxito operativo

Desde el punto de vista operativo, el PoC será considerado exitoso si:

- Las actividades se ejecutan dentro de las ventanas de tiempo acordadas con el cliente.
- No se generan impactos críticos en la operación productiva del entorno.
- presentación de resultados.
- Se logra completar las fases definidas en el cronograma de actividades.

8.3. Validación del valor de la solución

El PoC será considerado exitoso desde la perspectiva del negocio si:

- El cliente obtiene visibilidad clara sobre su postura actual de seguridad.
- Los reportes generados son considerados útiles para la gestión de vulnerabilidades.
- La información entregada permite priorizar acciones de remediación de manera efectiva.
- El cliente valida que la solución puede integrarse dentro de sus procesos operativos de seguridad.

8.4. Validación final del cliente

Como parte del cierre del PoC, se considerará el éxito global si:

- Se presenta un resumen ejecutivo con los principales hallazgos.
- Se entregan recomendaciones técnicas claras y accionables.
- El cliente confirma la correcta ejecución del PoC.
- Se obtiene retroalimentación del cliente sobre la percepción del valor de la solución.

9. Cierre

El Proof of Concept (PoC) se considerará formalmente concluido una vez finalizadas todas las actividades técnicas y operativas relacionadas con la evaluación de la plataforma SAINT Security Suite, desarrollada por SAINT Corporation, y tras la entrega de la documentación acordada con el cliente.

El cierre del PoC contempla la validación final de los resultados obtenidos, la presentación de hallazgos relevantes y la entrega de recomendaciones técnicas orientadas a la mejora de la postura de seguridad del entorno evaluado.

9.1. Actividades de cierre

Como parte del proceso de cierre, se deberán completar las siguientes actividades:

- Presentación final de resultados técnicos.
- Presentación de reporte técnico detallado de vulnerabilidades detectadas.
- Presentación de resumen ejecutivo con hallazgos principales y recomendaciones.
- Revisión conjunta de resultados con el cliente.
- Resolución de dudas técnicas relacionadas con los hallazgos.

9.2. Entregables finales

Al finalizar el PoC, se entregarán los siguientes documentos y evidencias:

- Reporte técnico completo de vulnerabilidades.
- Resumen ejecutivo orientado a toma de decisiones.
- Evidencias técnicas de ejecución (según aplique).
- Recomendaciones de remediación priorizadas.

10. Roles y responsabilidades

Durante la ejecución del PoC, las partes involucradas deberán cumplir con responsabilidades específicas para garantizar una ejecución ordenada, segura y efectiva del proceso de evaluación.

10.1. Responsabilidades del cliente

El cliente será responsable de:

- Definir el alcance de los activos a evaluar.
- Proporcionar accesos, credenciales y autorizaciones necesarias para la ejecución de las evaluaciones.
- Validar ventanas de ejecución para minimizar impacto operativo.
- Participar en sesiones técnicas de revisión de resultados.
- Validar la información obtenida durante la ejecución del PoC.
- Proporcionar retroalimentación durante la sesión final de resultados.

10.2. Responsabilidades del equipo técnico

El equipo técnico responsable de la ejecución del PoC será responsable de:

- Configurar correctamente los objetivos de escaneo.
- Ejecutar las evaluaciones de seguridad conforme al alcance aprobado.
- Monitorear la ejecución de los escaneos para garantizar estabilidad operativa.
- Analizar los resultados obtenidos durante la evaluación.
- Revisar resultados y recomendaciones técnicas

10.3. Consideraciones generales

- Todas las actividades serán ejecutadas bajo autorización del cliente.
- Se mantendrá comunicación continua entre las partes durante toda la ejecución del PoC.
- Cualquier cambio en el alcance deberá ser previamente acordado entre las partes.